

LindfoSec VMDR Practice Lab

First Real Remediation Cycle — LindfoSec-HR, CVE-2026-9545 (curl)

The first genuine end-to-end vulnerability management cycle run against a real finding in the LindfoSec lab: a Severity 5 curl vulnerability on LindfoSec-HR, detected, prioritized, and remediated with verified local evidence. Platform-side verification was still pending at session close, honestly documented as such rather than assumed complete. This session also involved substantial Cloud Agent on-demand scan troubleshooting, documented in full since the troubleshooting itself is genuine learning material.

1. The finding

Field	Value
Asset	LindfoSec-HR (Ubuntu 24.04.4, t3.micro)
QID	6035933 — Ubuntu Security Notification for curl Vulnerabilities (USN-8487-1)
Qualys Severity	5 of 5
CVEs covered	10 total under this one QID: CVE-2026-9545 (primary), plus 9080, 8458, 9547, 9079, 8286, 8926, 8925, 8927, 8924
Packages affected	curl, libcurl4t64, libcurl3t64-gnutls
Installed version (at detection)	8.5.0-2ubuntu10.9
Required version	8.5.0-2ubuntu10.10
Detection method	Authenticated, version-based: QID uses the system's package manager (dpkg) to enumerate packages and map them against vendor advisories — no active exploitation attempted

2. Lifecycle progress — honest status

Rather than rounding up to “complete,” each stage is marked on the actual evidence available at time of writing.

Stage	Status	Evidence
1. Detect	Done	QID 6035933 identified via VMDR → Assets → LindfoSec-HR → VMDR Vulnerabilities
2. Prioritize	Done	Correctly selected as highest priority: Severity 5, the top of two Severity-5 findings on this asset
3. Remediate	Done	sudo apt update && sudo apt install curl libcurl4t64 libcurl3t64-gnutls run via SSM; confirmed via dpkg -l showing all three packages at 8.5.0-2ubuntu10.11 (one patch level above the required version)
4. Verify (platform-side)	Pending	On-demand vulnerability scans submitted twice; local agent logs confirm requests were accepted, but QID 6035933 still showed status “New” (not “Fixed”) at session close

Assessment: 3.5 of 4 stages complete. Detection, prioritization, and remediation are fully evidenced. Platform-side verification is the one remaining piece — treated as genuinely outstanding rather than assumed, consistent with an “evidence, not assumption” approach to vulnerability tracking.

3. Remediation — commands run

```
sudo apt update  
sudo apt install curl libcurl4t64 libcurl3t64-gnutls
```

Local verification:

```
dpkg -l | grep curl
```

Result: all three packages showed ii (fully installed, no broken state) at version 8.5.0-2ubuntu10.11.

4. On-demand scan troubleshooting

Issue	Diagnosis	Resolution / Outcome
Console “On Demand Scan” action initially selected wrong scan type	Dropdown defaulted to “Inventory Scan,” not “Vulnerability Scan” — different manifest, doesn’t produce vulnerability findings	Identified correct option (“Vulnerability Scan”) in the dropdown before resubmitting
Dashboard “Last Checked In” appeared stuck at several days old across all assets	Column was actually showing Config Download timestamp, not live check-in time; confirmed via local log showing current, successful CAPI check-ins	Resolved by reading the correct column and trusting the local log as ground truth over a misleading dashboard label
First on-demand request appeared to produce no change after ~15 minutes	Restarting the Cloud Agent service as a troubleshooting step cleared the queued request before it executed	Resubmitted the on-demand command a second time; did not restart the service again
Second on-demand request accepted but QID still showed “New” after ~25+ minutes	Local log confirms request accepted and a subsequent scheduled check-in occurred; Qualys Community Edition carries no SLA and documents up to 24 hours for full result reporting	Left to complete naturally; platform status to be rechecked in a following session rather than re-triggered further

5. Follow-up and recommendations

- Recheck QID 6035933 on LindfoSec-HR in the next session, without re-triggering another on-demand scan first — the pending request, plus at least one natural scheduled interval, should have had time to complete and report a “Fixed” status.
- Once confirmed Fixed, capture a screenshot of that status change specifically — it is the strongest portfolio image for this project: a real before/after remediation outcome, not just infrastructure setup.
- Apply the same detect → prioritize → remediate → verify cycle to at least one finding on a second asset to demonstrate the process is repeatable, not a one-off.
- Keep the on-demand scan troubleshooting sequence in any documentation going forward, not smoothed over — it demonstrates methodical diagnosis under genuine ambiguity.
- After triggering any on-demand or asynchronous action, wait a full, undisturbed interval before troubleshooting further, rather than restarting services or resubmitting requests mid-wait.